COMPTIA SECURITY+ SY0-701 DOMÍNIO 1 · CONCEITOS GERAIS DE SEGURANÇA (12%)

Security+ 1.4 · Public Key Infrastructure (PKI)

Mestre CyberSec · **Aula 1.4 — Public Key Infrastructure (PKI)** (9:08) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Resumo Executivo da Aula:** PKI: o fundamento da criptografia moderna — SIMÉTRICA (AES — mesma chave, rápida, boa pra volume) vs ASSIMÉTRICA (RSA/ECC — par de chave pública/privada, lenta, boa pra troca e assinatura). Key escrow = cópia de chave em cofre.

💡 Highlights que a prova CompTIA cobra

- AES = simétrico; RSA = assimétrico
- Assimétrico: pública cifra, privada decifra (ou assina)
- PGP: combina a 2 (RSA pra trocar a chave + AES pro conteúdo)

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'requires a mathematical relationship between two cryptographic keys' = assimétrica (PKI)
- AES vs RSA: não confunde — a prova gosta de citar algoritmos

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 1.4 — Public Key Infrastructure (PKI))

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Infraestrutura de Chave Pública (PKI)
Estrutura de políticas, funções, hardware, software e procedimentos usados para criar, gerenciar, distribuir, armazenar e revogar certificados digitais e chaves públicas/privadas.

⚠️ ***Armadilha CompTIA:*** *Se a questão falar em certificados, CA, RA, CRL/OCSP e confiança em chaves públicas, o tema é PKI; não confunda com criptografia simétrica pura.*

• Padrão de Criptografia Avançado (AES)
Cifra de bloco simétrica que usa a mesma chave secreta para cifrar e decifrar dados; rápida e ideal para grandes volumes.

⚠️ ***Armadilha CompTIA:*** *"Mesma chave", "rápido", "bulk encryption" ou "simétrico" apontam para AES; não é usado para assinatura digital nem troca segura de chave por si só.*

• RSA (Rivest-Shamir-Adleman)
Algoritmo assimétrico baseado em relação matemática entre chave pública e privada; usado para troca de chaves, cifragem e assinaturas digitais.

⚠️ ***Armadilha CompTIA:*** *Gatilho "requires a mathematical relationship between two cryptographic keys" = RSA/assimétrica; lembre: pública cifra/verifica, privada decifra/assina.*

• Criptografia de Curva Elíptica (ECC)
Criptografia assimétrica que usa curvas elípticas sobre corpos finitos para oferecer segurança forte com chaves menores que RSA.

⚠️ ***Armadilha CompTIA:*** *Se a prova pedir assimétrico com chaves menores/mobile/IoT, escolha ECC; não é simétrico como AES.*

• Custódia de Chave / Key Escrow (N/A)
Armazenamento seguro de uma cópia de chaves de criptografia por terceiro confiável para recuperar dados se a chave original for perdida ou indisponível.

⚠️ ***Armadilha CompTIA:*** *Gatilho "cópia da chave em cofre" ou "recuperação de chave" = key escrow; não é o mesmo que backup comum de dados.*

• Pretty Good Privacy (PGP)

Programa/protocolo de criptografia que combina criptografia assimétrica para troca de chaves/assinaturas com criptografia simétrica para o conteúdo.

⚠️ ***Armadilha CompTIA:*** *Se a questão descrever "RSA para trocar a chave + AES para o conteúdo", pense PGP/híbrido; não diga que PGP é puramente simétrico ou assimétrico.*

• Autoridade Certificadora (CA)

Entidade confiável que emite, assina e gerencia certificados digitais, vinculando uma chave pública a uma identidade.

⚠️ ***Armadilha CompTIA:*** *Quem assina o certificado é a CA; se a questão falar em validação de identidade antes da emissão, pode ser RA, mas a assinatura final é da CA.*

• Lista de Revogação de Certificados (CRL)

Lista publicada de certificados digitais revogados antes da data de expiração e que não devem mais ser confiáveis.

⚠️ ***Armadilha CompTIA:*** *CRL = lista baixada/consultada; OCSP = status online em tempo real. Se a pergunta citar "lista", escolha CRL; se citar "consulta online", escolha OCSP.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Cadeia de Confiança: CA Raiz vs. CA Intermediária

🏠 **Analogia Intuitiva:** Pense no sistema nacional de cartórios. A CA Raiz é o Cartório Central Nacional, guardado a sete chaves em um cofre no subsolo da capital, cujo livro-mestre é aberto apenas uma vez por década sob escolta armada. Como seria um pesadelo logístico e de segurança usar esse livro nacional todo dia, o Cartório Central emite delegações oficiais para Cartórios de Bairro (CAs Intermediárias). São essas filiais que atendem o cidadão no balcão e carimbam as certidões de nascimento. Se um cartório de bairro for invadido ou pegar fogo, o Cartório Central revoga apenas aquela filial intermediária, sem cancelar as certidões do resto do país e sem que o cofre mestre seja violado.

🔍 **Causa Raiz / Por que foi criado:** Se a Autoridade Certificadora Raiz fosse mantida online conectada à internet para assinar os milhões de sites criados diariamente, qualquer falha no servidor ou invasão hacker comprometeria a chave privada mestre global, destruindo a confiança de toda a internet mundial. A hierarquia de CA com CAs intermediárias operacionais isola a Raiz offline, contendo danos em caso de incidente.

🛡️ **Visão do Auditor de GRC:** O auditor de GRC deve exigir evidências documentais de que a CA Raiz corporativa está desconectada da rede (Air-Gapped / Offline Root CA) e mantida em ambiente físico seguro (Cofre com blindagem e controle de acesso biométrico). É obrigatório inspecionar as atas da 'Key Ceremony' (cerimônia formal de geração de chaves filmada com múltiplos custodiantes) e validar a segregação de funções entre administradores da PKI e operadores de emissão.

⚠️ **Como cai na Prova CompTIA:** Gatilhos da prova: 'isolate the root certificate authority from network exposure' -> Offline Root CA; 'subordinate authority used for routine daily issuance' -> Intermediate CA; 'compromise of a signing authority without collapsing the entire trust model' -> Revoke the Intermediate CA.

📌 CSR (Certificate Signing Request) & Chave Privada vs. Pública

🏠 **Analogia Intuitiva:** Imagine tirar uma Carteira Nacional de Habilitação (CNH). Você vai a um estúdio fotográfico particular, tira a sua foto 3x4 oficial e colhe suas digitais. Você coloca a foto e seus dados cadastrais em um formulário de requerimento oficial (o CSR) e entrega no balcão do Detran (a CA). O Detran valida seus documentos, cola o carimbo holográfico oficial sobre a sua foto e te devolve a CNH pronta (o Certificado Digital). O Detran nunca viu a sua casa ou seus segredos pessoais; você apenas enviou sua foto pública no requerimento para que ela recebesse a assinatura de fé pública.

🔍 **Causa Raiz / Por que foi criado:** A chave privada do servidor NUNCA deve sair do computador de origem nem trafegar pela rede. Se o usuário pedisse para a CA gerar a chave privada para ele, a CA teria uma cópia de sua chave secreta e poderia se passar pelo servidor. O CSR foi criado para que o servidor gere localmente o par de chaves, guarde a privada e envie apenas a pública com a identificação para assinatura.

🛡️ **Visão do Auditor de GRC:** Auditar a política de geração de CSR nos sistemas da organização. Verificar se o tamanho mínimo da chave no CSR atende aos padrões do NIST (mínimo RSA 2048 bits ou ECC 256 bits). Confirmar que o processo de submissão do CSR não exporta ou inclui a chave privada e que as chaves privadas geradas são marcadas como não-exportáveis ou armazenadas em HSM/TPM.

⚠️ **Como cai na Prova CompTIA:** Gatilhos da prova: 'first step in requesting an SSL/TLS certificate from a public CA' -> Generate a key pair and create a CSR; 'what cryptographic component is included in a CSR' -> The public key (pegadinha clássica: a chave PRIVADA NUNCA vai no CSR).

📌 Revogação: CRL vs. OCSP vs. OCSP Stapling

🏠 **Analogia Intuitiva:** Imagine uma loja checando se um cheque ou cartão de crédito é roubado. A CRL (Certificate Revocation List) é como a administradora enviar semanalmente pelo correio uma lista telefônica gigantesca com todos os cheques roubados do país: o caixa da loja precisa folhear milhares de páginas a cada compra (lento, pesado e fica desatualizado entre as publicações). O OCSP (Online Certificate Status Protocol) é o caixa ligar em tempo real na central para perguntar 'este cheque de número 123 está cancelado agora?': a resposta é imediata, mas a central fica congestionada com milhões de ligações e o operador da central sabe exatamente em qual loja você está comprando. Já o OCSP Stapling é o próprio cliente trazer junto com o cheque um comprovante fresquinho, carimbado digitalmente pela central nos últimos 5 minutos, dizendo 'este cheque está liberado': a loja confere o carimbo na hora, ninguém precisa ligar para a central e a privacidade das compras fica protegida.

🔍 **Causa Raiz / Por que foi criado:** Certificados têm validade longa (geralmente 1 ano), mas se a chave privada do servidor for vazada no dia seguinte à emissão, o certificado precisa ser invalidado imediatamente. A CRL original consumia banda excessiva e criava janelas de vulnerabilidade entre atualizações. O OCSP resolveu o tempo real, mas gerou problemas de sobrecarga na CA e quebra de privacidade (a CA sabia todos os sites que o usuário visitava). O OCSP Stapling resolveu ambos os gargalos.

🛡️ **Visão do Auditor de GRC:** Verificar se a infraestrutura corporativa possui monitoramento contínuo de expiração de certificados e revogação em tempo hábil. Auditar as configurações de servidores web voltados ao público para garantir que o OCSP Stapling esteja ativado (melhoria de resiliência, latência e privacidade). Assegurar que firewalls e proxies permitam o tráfego de saída para pontos de distribuição de CRL e respondedores OCSP.

⚠️ **Como cai na Prova CompTIA:** Gatilhos da prova: 'periodic published list of invalid certificates causing high bandwidth consumption' -> CRL; 'real-time certificate status check protocol' -> OCSP; 'web server appends a time-stamped CA verification to the TLS handshake to reduce CA query load and protect privacy' -> OCSP Stapling.

📌 Key Escrow & Controle Colegiado M-de-N (M-of-N Control)

🏠 **Analogia Intuitiva:** Imagine o cofre de herança de uma família guardado no cartório. Se o chefe da família falecer repentinamente sem deixar a senha, o patrimônio da família ficaria bloqueado para sempre. O Key Escrow é o serviço de custódia onde uma cópia de segurança da chave fica confiada a uma entidade neutra ou comitê, liberada apenas sob estrito mandado judicial ou processo de emergência. Para garantir que nenhum funcionário do cartório abra o cofre sozinho por capricho, usa-se a regra M-de-N: o segredo do cofre é fatiado em 5 pedaços diferentes (N=5), e a abertura exige a presença física de pelo menos 3 membros do conselho (M=3) girando suas respectivas chaves simultaneamente.

🔍 **Causa Raiz / Por que foi criado:** Se um funcionário que criptografa dados corporativos confidenciais for demitido, sofrer um acidente fatal ou esquecer a senha, a empresa perderia o acesso definitivo aos seus próprios ativos digitais sem o Key Escrow. Por outro lado, deixar a chave de recuperação inteira nas mãos de um único administrador cria o risco inaceitável de espionagem interna e roubo de dados, solucionado pelo princípio da divisão de segredos (M-of-N).

🛡️ **Visão do Auditor de GRC:** Avaliar o procedimento de gerenciamento de chaves (Key Management Policy conforme NIST SP 800-57). O auditor deve validar que o Key Escrow possui cadeia de custódia formal, logs de auditoria imutáveis para qualquer tentativa de recuperação e aplicação de 'Dual Control' ou 'Split Knowledge' (M-de-N), garantindo que nenhum indivíduo isole o poder de recuperar chaves de decodificação.

⚠️ **Como cai na Prova CompTIA:** Gatilhos da prova: 'third party securely stores copies of private encryption keys for lawful recovery' -> Key Escrow; 'requires a minimum threshold of authorized custodians out of a total group to reconstruct a cryptographic master key' -> M-of-N control (Split Knowledge / Dual Control).

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
CA principal mantida permanentemente desconectada da rede para evitar comprometimento global	**Offline Root CA (CA Raiz Offline)**
Arquivo gerado no servidor contendo a chave pública e enviado à CA para emissão de certificado	**CSR (Certificate Signing Request)**
Verificação em tempo real do status de revogação de um certificado individual consultando a CA	**OCSP (Online Certificate Status Protocol)**
Servidor web anexa a resposta da CA com selo de tempo no handshake TLS para aliviar a carga e proteger privacidade	**OCSP Stapling**
Cópia de segurança de chaves de criptografia mantida sob custódia para recuperação judicial ou emergencial	**Key Escrow**
Procedimento de segurança exigindo que pelo menos 3 de 5 diretores forneçam suas partes para reconstruir a chave mestra	**Controle M-de-N (Split Knowledge / M-of-N)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma organização de saúde precisa criptografar 500 GB de registros de pacientes em fitas de backup que serão armazenadas fora do local. A equipe de segurança requer criptografia forte enquanto minimiza a sobrecarga de processamento, pois a operação de criptografia deve ser concluída dentro de uma janela apertada de backup noturno. Qual algoritmo de criptografia a equipe deve implementar?

A) Advanced Encryption Standard (AES)

B) RSA com chaves de 4096 bits

C) Criptografia de Curva Elíptica (ECC)

D) Troca de chaves Diffie-Hellman

QUESTÃO 2 · CENÁRIO DE EXAME

Um fornecedor de software distribui atualizações mensais para milhares de clientes em todo o mundo. O fornecedor deseja que os clientes possam verificar que as atualizações vieram dele e não foram modificadas em trânsito. O fornecedor também quer garantir que não possa negar posteriormente ter lançado uma atualização específica. Qual abordagem criptográfica o fornecedor deve usar para assinar as atualizações?

A) Assinar o hash da atualização com a chave privada do fornecedor; clientes verificam com a chave pública do fornecedor

B) Assinar o hash da atualização com a chave pública do fornecedor; clientes verificam com a chave privada do fornecedor

C) Criptografar toda a atualização com a chave privada do fornecedor; descriptografar com a chave pública do fornecedor

D) Criptografar toda a atualização com a chave pública do fornecedor; descriptografar com a chave privada do fornecedor

QUESTÃO 3 · CENÁRIO DE EXAME

Uma instituição financeira requer que todos os dados de clientes permaneçam acessíveis por um mínimo de sete anos conforme os requisitos regulatórios. O diretor de risco está preocupado que, se um funcionário que originalmente criptografou os dados sair da empresa ou perder sua chave de criptografia, a instituição possa ficar bloqueada fora de registros históricos críticos. Qual solução a instituição deve implementar para mitigar esse risco?

A) Custódia de chaves (key escrow) com um terceiro confiável

B) Lista de Revogação de Certificados (CRL)

C) Fixação de certificado de Infraestrutura de Chave Pública (PKI)

D) Rotação de Perfect Forward Secrecy (PFS)

QUESTÃO 4 · CENÁRIO DE EXAME

Um consultor de TI independente troca regularmente contratos confidenciais de clientes e documentos de planejamento estratégico com um parceiro de negócios de longa data por e-mail. Eles querem garantir que apenas o destinatário pretendido possa ler os documentos e que o destinatário possa confirmar que os documentos realmente vieram do consultor. Qual tecnologia é projetada especificamente para esse cenário?

A) Pretty Good Privacy (PGP)

B) Assinatura de Server Message Block (SMB)

C) Wired Equivalent Privacy (WEP)

D) Lightweight Directory Access Protocol (LDAP) sobre SSL

QUESTÃO 5 · CENÁRIO DE EXAME

Uma empresa de médio porte deseja implementar HTTPS em suas aplicações web internas para que os funcionários possam verificar se estão se conectando a servidores legítimos da empresa. A empresa precisa de uma entidade interna para verificar as identidades dos servidores e emitir os certificados digitais que serão instalados nesses servidores internos. Qual componente da PKI executa essa função?

A) Autoridade Certificadora (CA - Certificate Authority)

B) Autoridade de Registro (RA - Registration Authority)

C) Extensões de Segurança do Sistema de Nomes de Domínio (DNSSEC)

D) Respondedor do Protocolo de Status de Certificado Online (OCSP)

QUESTÃO 6 · CENÁRIO DE EXAME

Um funcionário sai da empresa, e o administrador de segurança deve impedir imediatamente que qualquer sistema confie no certificado do smart card do funcionário que está saindo, mesmo que o certificado ainda seja tecnicamente válido por mais onze meses. Qual mecanismo de PKI permite ao administrador invalidar o certificado antes de sua expiração natural?

A) Adicionar o certificado a uma Lista de Revogação de Certificados (CRL) publicada pela CA

B) Esperar o certificado expirar e então emitir um novo

C) Redefinir o smart card do funcionário e reutilizar o mesmo número de série do certificado

D) Renovar o certificado com a mesma chave pública mas um novo período de validade

QUESTÃO 7 · CENÁRIO DE EXAME

Uma startup está projetando uma nova linha de sensores IoT alimentados por bateria que devem autenticar com segurança em uma API de nuvem usando criptografia assimétrica. Os sensores têm um processador ARM de baixo consumo, apenas 64 KB de RAM e operam por anos com uma única bateria tipo moeda. O diretor de tecnologia quer a segurança prática mais forte sem sacrificar a vida útil da bateria. Qual algoritmo assimétrico é mais adequado para essas restrições?

A) Criptografia de Curva Elíptica (ECC) usando uma chave de 256 bits

B) RSA usando uma chave de 4096 bits

C) RSA usando uma chave de 2048 bits

D) Triple DES (3DES) usando três chaves de 56 bits

QUESTÃO 8 · CENÁRIO DE EXAME

Durante um handshake TLS entre o navegador de um usuário e um servidor web, o navegador deve transmitir com segurança uma chave de sessão simétrica gerada aleatoriamente para o servidor. Após essa troca, todos os dados da aplicação subsequentes são criptografados usando a chave simétrica compartilhada porque a criptografia simétrica é muito mais eficiente. Qual chave o navegador usa para criptografar a chave de sessão antes de transmiti-la ao servidor?

A) A chave pública do servidor obtida do certificado digital do servidor

B) A chave privada do servidor armazenada no servidor web

C) A chave pública do navegador enviada na mensagem ClientHello

D) A chave privada do navegador armazenada no repositório de certificados do usuário

QUESTÃO 9 · CENÁRIO DE EXAME

Um administrador de banco de dados deve criptografar um arquivo de backup de banco de dados de produção de 10 GB que será arquivado para armazenamento de longo prazo. Os mesmos administradores confiáveis que precisam restaurar o arquivo em um cenário de recuperação de desastres deterão a chave, e a operação de criptografia deve ser concluída dentro da janela de manutenção disponível. Qual tipo de criptografia é mais adequado para este cenário?

A) Criptografia simétrica usando AES-256 com uma chave secreta compartilhada

B) Criptografia assimétrica usando RSA com uma chave de 2048 bits

C) Criptografia assimétrica usando ECC com uma chave de 256 bits

D) Criptografia híbrida usando apenas Diffie-Hellman para o payload de dados

QUESTÃO 10 · CENÁRIO DE EXAME

Uma corporação multinacional está implantando uma PKI para suportar 40.000 funcionários, 500 servidores internos e várias aplicações voltadas para parceiros. Em vez de emitir cada certificado diretamente de uma única raiz, os arquitetos projetam um modelo onde uma única CA raiz offline assina os certificados de várias CAs intermediárias, que por sua vez emitem certificados para servidores e usuários de entidade final. Qual é esse modelo de confiança hierárquica chamado?

A) Cadeia de confiança (PKI hierárquica)

B) Teia de confiança (web of trust)

C) Federação de âncoras de confiança

D) Conjunto de certificados autoassinados

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Advanced Encryption Standard (AES)

AES é um algoritmo de criptografia simétrica que usa a mesma chave para criptografar e descriptografar. Para grandes volumes de dados como 500 GB, a criptografia simétrica é dramaticamente mais rápida e eficiente que algoritmos assimétricos como RSA ou ECC. A criptografia assimétrica é reservada para troca de chaves e assinaturas digitais devido à sua sobrecarga computacional. AES-256 fornece criptografia forte, aprovada pelo FIPS, adequada para dados de saúde regulamentados.

Questão 2: Alternativa A — Assinar o hash da atualização com a chave privada do fornecedor; clientes verificam com a chave pública do fornecedor

Para fornecer integridade e não repúdio, o fornecedor deve assinar a atualização com sua chave privada. Apenas o fornecedor tem acesso a essa chave privada, então somente o fornecedor poderia ter produzido a assinatura. Os clientes usam a chave pública amplamente distribuída do fornecedor para verificar a assinatura e confirmar que a atualização não foi alterada. Criptografar o arquivo inteiro é ineficiente e desnecessário; assinar o hash fornece as mesmas garantias a uma fração do custo.

Questão 3: Alternativa A — Custódia de chaves (key escrow) com um terceiro confiável

A custódia de chaves (key escrow) é a prática de armazenar com segurança uma cópia das chaves de criptografia com um terceiro confiável ou em um cofre interno reforçado. Isso garante que os dados criptografados possam ser recuperados mesmo se o detentor original da chave estiver indisponível, perder a chave ou sair da organização. É comumente usado em indústrias regulamentadas para atender aos requisitos de retenção de dados. CRL, fixação de certificado e PFS não abordam a recuperação de chaves de criptografia.

Questão 4: Alternativa A — Pretty Good Privacy (PGP)

Pretty Good Privacy (PGP) é projetado especificamente para proteger comunicações de e-mail e arquivos entre indivíduos. Ele usa uma combinação de criptografia simétrica (para o corpo da mensagem) e criptografia assimétrica (para proteger a chave simétrica), junto com assinaturas digitais para autenticidade e não repúdio. A assinatura SMB protege compartilhamentos de arquivos, WEP é um protocolo de segurança sem fio obsoleto, e LDAPS protege consultas de diretório — nenhum aborda e-mail seguro entre duas partes.

Questão 5: Alternativa A — Autoridade Certificadora (CA - Certificate Authority)

Uma Autoridade Certificadora (CA) é a entidade confiável dentro de uma PKI que verifica a identidade dos solicitantes de certificados e emite certificados digitais assinados vinculando uma chave pública a uma identidade. A assinatura da CA no certificado permite que as partes confiantes confiem na vinculação. Uma RA apenas verifica identidades e encaminha solicitações para uma CA; DNSSEC protege registros DNS; e respondedores OCSP relatam o status do certificado. Nenhum deles realmente emite certificados.

Questão 6: Alternativa A — Adicionar o certificado a uma Lista de Revogação de Certificados (CRL) publicada pela CA

Uma Lista de Revogação de Certificados (CRL) é uma lista assinada e com carimbo de tempo publicada pela CA emissora que identifica certificados que foram revogados antes de sua expiração programada. As partes confiantes consultam a CRL durante a validação do certificado para garantir que não estão aceitando um certificado revogado. Esperar pela expiração natural deixa uma lacuna de segurança inaceitável; reutilizar números de série é criptograficamente perigoso; e renovar com a mesma chave não aborda a perda de confiança.

Questão 7: Alternativa A — Criptografia de Curva Elíptica (ECC) usando uma chave de 256 bits

A Criptografia de Curva Elíptica (ECC) fornece segurança equivalente ao RSA enquanto usa tamanhos de chave dramaticamente menores — uma chave ECC de 256 bits oferece resistência comparável a uma chave RSA de 3072 bits. Chaves menores significam certificados menores, menor consumo de memória, cálculos mais rápidos e consumo de energia significativamente menor. 3DES é um algoritmo simétrico e é obsoleto independentemente do caso de uso. Os tamanhos de chave RSA escolhidos seriam ou muito consumidores de energia ou insuficientes para segurança de longo prazo.

Questão 8: Alternativa A — A chave pública do servidor obtida do certificado digital do servidor

O navegador criptografa a chave de sessão simétrica com a chave pública do servidor, que ele recupera do certificado digital do servidor durante o handshake. Apenas a chave privada correspondente do servidor pode descriptografar esse valor, garantindo que nenhum interceptador possa recuperar a chave de sessão mesmo se a troca for interceptada. Depois que ambos os lados possuem a chave de sessão, eles mudam para criptografia simétrica para transferência de dados em massa devido às suas vantagens de desempenho.

Questão 9: Alternativa A — Criptografia simétrica usando AES-256 com uma chave secreta compartilhada

A criptografia simétrica como AES-256 usa uma única chave secreta compartilhada para criptografar e descriptografar e é ordens de magnitude mais rápida que algoritmos assimétricos. Como o mesmo pessoal precisa criptografar e descriptografar o arquivo, compartilhar a chave simétrica é operacionalmente direto. A criptografia assimétrica de 10 GB de dados seria proibitivamente lenta, e Diffie-Hellman é um protocolo de acordo de chaves, não um algoritmo de criptografia de dados.

Questão 10: Alternativa A — Cadeia de confiança (PKI hierárquica)

Uma cadeia de confiança, também chamada PKI hierárquica, é a topologia PKI mais comum. A confiança flui de uma única CA raiz para baixo através de uma ou mais CAs intermediárias para certificados de entidade final. Cada certificado é assinado pela entidade imediatamente acima dele na hierarquia, então os verificadores podem rastrear a confiança de volta a uma raiz conhecida. Uma teia de confiança é o modelo descentralizado usado pelo PGP; não há uma única âncora. Federação de âncoras de confiança e conjuntos de certificados autoassinados não são modelos de confiança PKI padrão.